MUESTRA DE PORTAFOLIO — ANONIMIZADO

Auditoría de seguridad — Red interna de MoldTek Industrial

Xavier Margalef — Reconocimiento no intrusivo (MSA-Interno)

6 de octubre de 2026
Rango auditado: 192.168.1.0/24

Conclusión inicial: Riesgo global **MEDIO**. No hay vulnerabilidades críticas activas, pero la combinación de credenciales sin cifrar, falta de segmentación de red y software desactualizado constituye un patrón de riesgo que debe corregirse antes de que se convierta en incidente.

Medio Bajo Informativo (sin riesgo directo, mejora de higiene)

HALLAZGOS (DE MAYOR A MENOR SEVERIDAD)

ID	Hallazgo	IP(s) — red 192.168.1.0/24	Severidad	CVE / CWE	Impacto	Corrección
MAT-06	Servidor Apache 2.4.58 sin actualizar, expuesto y sin dueño identificado	192.168.1.244	**MEDIO**	CVE-2024-24795 (CVSS 6.3)	HTTP response splitting si se publica una app real sin parchear antes	Actualizar a Apache ≥2.4.59 o dar de baja el servidor si no está en uso
MAT-04	Credenciales de administración de impresora Canon transmitidas sin cifrar (HTTP)	192.168.1.10	**MEDIO**	CWE-319/523 (CVSS 5.9)	Captura de contraseña de administración por cualquiera en el mismo segmento	Activar HTTPS en la interfaz de gestión o restringirla a VLAN de administración
MAT-07	RDP del Controlador de Dominio accesible desde toda la red de usuarios	192.168.1.100	**MEDIO**	CWE-1008	Amplía la superficie de ataque sobre el activo más crítico (identidad del dominio)	Restringir RDP a VLAN de administración o jump host; NLA ya activo (correcto)
MAT-05	Sin segmentación entre puestos de usuario e infraestructura crítica (iDRAC, hipervisores, NAS)	.112 (iDRAC) · .245/.249/.250/.254 (ESXi) · .98 (NAS)	**MEDIO**	CWE-1008	Un puesto de usuario comprometido llega directo a toda la infraestructura crítica	Crear VLAN de gestión dedicada para iDRAC/ESXi/NAS, con acceso restringido
MAT-01	Puerto SMB abierto en el servidor principal, versión sin confirmar	192.168.1.100	**BAJO**	CWE-200	Si fuera SMBv1: vector histórico de EternalBlue/WannaCry	Confirmar versión con acceso administrativo; deshabilitar SMBv1 si estuviera activo
MAT-02	Servidor interno (IIS) sin TLS — tráfico sin cifrar tras la autenticación	192.168.1.100	**BAJO**	CWE-319	Tráfico de sesión interceptable en el mismo segmento (no las credenciales)	Forzar HTTPS con certificado válido y redirección 80→443
MAT-03	Clúster de hipervisores ESXi con al menos dos niveles de parcheo distintos	.245/.254 (build A) · .249/.250 (build B)	**INFO.**	CWE-1188	El host menos actualizado concentra más vulnerabilidades sin corregir	Uniformizar el nivel de parche de todo el clúster

IMPACTO POTENCIAL SI NO SE CORRIGE

Ámbito	Exposición
Legal	RGPD Art. 83 — hasta **10M€/2%** de facturación (nivel inferior) o **20M€/4%** (nivel superior) si una vulneración deriva en brecha de datos personales confirmada. Ningún hallazgo es en sí una brecha (MAT-04 expone credenciales del dispositivo, no datos de personas), pero son el tipo de debilidad de acceso que el Art. 32 RGPD exige prevenir, y podrían derivar en una si se encadenan con datos ya almacenados (carpetas de SERVIDOR, agendas de la impresora).
Económico	El coste medio global de una brecha de datos en 2025 es de **4,44M$** (IBM Cost of a Data Breach Report 2025) — cifra agregada y orientativa, no una estimación específica para MoldTek Industrial, que dependerá de su tamaño y sector real.
Operativo / reputacional	Si se confirma el equipo de automatización industrial en la misma red plana (ver contexto no verificado), un incidente no afectaría solo a sistemas de oficina, sino potencialmente a la producción. A esto se suma el riesgo de pérdida de confianza de clientes/proveedores tras un incidente visible.

Alcance y método: reconocimiento no intrusivo (MSA-Interno, red interna 192.168.1.0/24), sin explotación ni captura de credenciales. 92 hosts confirmados por evidencia propia; ≈109 según inventario previo del equipo (impresoras, DECT, cámaras, puntos de acceso, servidores), no re-verificado host por host. Normativa: ISO/IEC 27001:2022, ENS (RD 311/2022)/CCN-STIC, CIS Controls v8, MITRE ATT&CK, NIS2 (aplicabilidad a confirmar).
Contexto adicional no verificado (reconocimiento previo del equipo, no confirmado en este ejercicio): posible equipo de automatización industrial (marca no identificada, grupo NetBIOS "GRUPO-IND") en el mismo segmento que los puestos de usuario — refuerza MAT-05; carpetas compartidas (incl. una de software de contabilidad) y usuarios locales enumerables por SMB en varios servidores — indicio de enumeración sin autenticación fuerte.
Fuentes del impacto potencial: Reglamento (UE) 2016/679 (RGPD), Art. 83; IBM Cost of a Data Breach Report 2025. Informe técnico completo con evidencia y trazabilidad disponible por separado.